agentbridge 产品白皮书

Agent 协作的交付证据层：可验证、可归责、可审计

版本 0.9.3 | 2026-10-22 | agentbridge authors

MIT License

目录

摘要

1　问题：Agent 协作的「证据缺口」

2　为什么现有工具不够

3　设计立场

4　产品能力（0.9.3）

5　信任模型：保证与不保证

6　验证与证据

7　商业价值：卖的是争议发生时的确定性

8　客户与场景

9　行业定位：AI 安全中的取证层

10　商业模式与路线

11　术语表

摘要

多个 AI Agent 协作时，真正的困难不是让它们说话，而是交付之后能证明：哪一版交给了谁、对方验收了没有、记录有没有被改过。日志可以被改写，聊天记录可以被撤回，平台常常自己就是交易的一方；当协作跨越两个组织，双方手里往往只剩互相矛盾的截图与邮件。

agentbridge 是 **Agent 协作的交付证据层**：为跨团队、跨供应商的 AI 工作流生成可离线、可被对端独立核验的交付凭证。它不裁决对错、不证明质量，只把「承诺—交付—验收」固定成可核验的事实：逻辑交付 ID、版本、附件摘要、验收/拒收、修订关系与密钥时间线，全部进入签名账本，并能导出为一份证据包。

需求是多方位、但指向同一件事。技术团队担心同机 Agent 互不可信、记录可被悄悄改写；交付团队担心版本和验收说不清；合规团队要向第三方证明「交付确实发生、内容没变、谁签的」；平台要把第三方 Agent 的准入与责任边界产品化；研究者要可复现的协作记录。它们要的不是又一个日志系统，而是同一份能被对端独立核验的交付证据。

我们不承诺「不可篡改」，只承诺「改了能被发现」；最后一道防线——一个必须由人保管在机器之外的锚点——明确交还给人。这是一个更小的承诺，也是唯一能被真正兑现的承诺。本白皮书说明问题、设计立场、产品能力与边界，以及它是如何被对抗性验证推进到 v0.2 的。

关键词：多智能体协作 / Agent 交付核验 / 跨组织协作 / 可归责审计 / Ed25519 / 外部锚点 / 离线核验 / MCP

阅读对象与章节导览

本文供 Agent 平台团队、交付服务商、安全与审计团队、潜在试点合作方阅读。章节顺序：问题与需求地图 → 现有工具不足 → 设计立场 → 产品能力 → 信任边界 → 验证证据 → 商业价值 → 客户场景 → 标准对应 → 试点与路线。

文中区分三类内容：已实现的能力、已验证的证据、仍待客户验证的商业假设。标准条款只用于定义需求方向，不构成认证或符合性结论。

1　问题：Agent 协作的「证据缺口」

一个典型场景：AI 服务商把交付物交给客户，客户验收后又发现一处问题，要求返工。双方开始翻聊天记录：客户说「我验收的是第二版」，服务商说「你验收的其实是第一版」；邮件里的附件已经替换，群里的文件被清理，平台的提交记录只站在平台自己一边。

AI 让交付变快，也让交付证据变薄：内容由模型生成、版本迭代频繁、协作跨组织、记录散落在不同系统。争议发生时，最贵的不是返工，而是**对齐事实**。

1.1 三种具体的失败模式

失败模式	具体表现	后果
交付版本说不清	客户验收的是 v2，记录里只写着「报告」	争执谁签了哪一版，返工无法归责
验收被错绑	验收记录指向了另一个版本或另一批附件	「验收通过」被错误引用
记录被改/被截断	同一台机器、同一个账号，记录与锚点一起被重写	证据消失，且看起来仍然自洽

这些失败不需要攻破密码学，只需要在同一个权限下改几个文件；而多数「AI 协作平台」恰好假定这不会发生。

1.2 为什么现有日志不够

日志记录的是**事件**：谁在什么时候调用了什么。交付争议要回答的是**对价关系**：承诺了什么、交付了哪一版、谁验收的、理由是什么、后续怎么修订。两者不是一回事。

1.3 需求地图：五种视角，同一个缺口

同一份交付证据，在不同角色眼里是不同的采购理由。白皮书不把其中任何一种当成产品的全部，而是说明它们为什么最终都落到同一份凭证上。

视角	真实痛点	需要的能力
Agent / 运行时	同机多 Agent 互不信任；日志、head、锚点可被同一权限改写；尾截断无感	哈希链 + 逐条签名 + 外部锚点；失败关闭
跨组织交付	客户验收的是 v2，记录只写「报告」；拒收理由散落聊天；返工无法归责	逻辑交付 + 版本 + 验收/拒收 + 修订关系
合规 / 审计	要向甲方或审计方证明「交付确实发生、内容未变、谁签的」，且对方愿独立复核	可导出证据包 + 离线核验器 + 明确披露未证明项
平台 / 生态	第三方 Agent 准入、责任边界、白标能力；自研成本高、周期长	可集成组件 + MCP/HTTP + 证据格式与验证器
开发 / 研究	多 Agent 实验不可复现；记录格式各写各的；缺乏统一核验	开源核心 + CLI/Python API + 固定测试向量

1.4 一个产品，五种读法

对 Agent 开发者，它是一个可嵌入的交付记录层；对服务商，它是「这次交付出了问题，我们很快能对齐版本和记录」；对平台，它是第三方 Agent 的准入与责任边界组件；对审计方，它是一份能被独立复核的证据包；对研究者，它是一套可复现的协议与测试。产品定义不随读法改变：**同一份可验证的交付凭证。**

这也是为什么本白皮书既谈技术威胁模型，也谈交付、审计与商业——不是把产品说大，而是把同一个缺口从五个方向说清楚。

2　为什么现有工具不够

方案	它能回答的	它回答不了的
聊天/工单/日志	当时大概说了什么	版本是否被替换、验收绑定的是哪一版
电子签/时间戳	某份文件在这一刻存在过	交付过程、拒收理由、修订与再验收
平台评分/托管	平台愿意背书	平台自己参与交易时，裁判兼球员
区块链存证	某条哈希在链上出现过	上链前事实是否真实、身份是谁、内容是否被复核
中心化审计系统	一次集中的事后调查	两个互不信任的组织之间，谁当中心

缺的那一块是：在**没有共同权威**的两方之间，用最低的信任成本留下可被任何第三方独立核验的证据，并明确标注它证明不了什么。

3　设计立场

3.1　可验证，而不是「不可篡改」

在同一个系统用户下，没有文件真正不可改。所以我们只承诺：改了能被发现。这个区别决定了产品措辞、报告格式与测试策略。

3.2　分层信任，每层写清边界

内容寻址解决附件被替换；哈希链解决中间行被改；head 锚点解决尾部截断；外部锚点解决账本与 head 一起被改；Ed25519 解决「谁签的」；密钥时间线解决「换过钥之后，这条记录当时是谁签的」。每层只解决一件事。

3.3 锚点必须在机器之外

写在同一个文件系统上的校验值，最终都能被同一用户重写。唯一例外是被抄走、发给第三方或写进工单的值。产品必须提供顺手的动作，而不是一句建议。

3.4 失败关闭，限制写进报告

状态说不清时，工具应当报错而不是猜；所有恢复动作显式留痕。报告必须直接写出「未复核内容」「离线无法确认为最新历史」等限制，避免把「摘要未变」误读成「交付合格」。

4 产品能力（0.9.3）

能力	提供的保证
哈希链账本	seq/prev/digest 连续，中间改行与被截断可发现；追加失败关闭
信封与工件	请求/交付正文与附件清单签名；附件按 sha256 内容寻址
验收与拒收	绑定逻辑交付 + 版本 + 工件哈希集合；拒收必须带理由
交付修订	v1 拒收 → v2 重交 → 再验收；验收 v1 不会自动变成验收 v2
密钥时间线	register / rotate / revoke 绑定账本序号与摘要；按记录选当时有效钥
证据包 v0.2	账本切片、信封、验收、状态、回执、密钥历史逐字节保留，manifest 签名
离线核验器	六轴：完整性 / 身份 / 验收 / 覆盖 / 锚定 / 内容；输出原因码与披露
外部锚点	服务签名回执对抗账本与 head 协同重写

交付形态：MIT 开源核心、CLI、Python API、MCP server、HTTP 单写序列器、托管锚点服务。

4.1 旧版本仍保留证据价值

superseded 只表示旧版本被后续版本替代，不表示旧证据可以跳过验证。旧版本的签名、版本与工件绑定、历史验收仍需逐项核验；「当前目标版本是否符合预期」与「历史是否真实」是两件事，不能因为前者不再是当前目标就放过后者。

4.2 支持能力 ≠ 已满足运行要求

产品提供轮换/撤销命令，不等于客户已经实现按计划轮换、调度执行、逾期处理与运行记录；产品能把事件记成证据，不等于组织的身份流程已经合规。部署评估应逐项记录「组件能力、配置、运行证据、剩余缺口」。

5 信任模型：保证与不保证

保证	不保证
交付摘要与签署记录可离线核验，且能被对端独立复核	复核附件内容（`hashes_only` 模式明确不执行）
验收绑定到具体版本与哈希集合；旧版本被取代有标记	业务交付质量是否合格
中间改行、尾截断、验收移植、修订历史被重写可发现	离线自行确认「这是最新全部历史」
密钥轮换由旧钥授权；撤销不追溯否定历史签名	密钥保管是否安全；泄露后的恢复（需 K3）
签名证明密钥持有者；时间线证明记录当时由谁签	身份背后是不是你想象中的那个人

最重要的一行：这套系统不裁决。它把「谁承诺了什么、交付了什么、谁验收了」变成可核验的事实，但「这算不算违约」永远是人的判断。

5.1 hashes_only 披露（接收方必读）

证据包默认只带摘要，不带附件内容。因此核验报告必须直接写出：「核验的是交付摘要与签署记录，未复核文件内容。」这不是免责声明，是使用边界。

5.2 包内公钥不建立身份

manifest 中的公钥即使与签名匹配，也只说明包内材料彼此一致。接收方必须通过独立渠道确认预期的签署身份、锚点服务公钥与撤销发布者；把信任文件放在包外只是加载约束，并不能证明文件来源可信。

5.3 可信时间只限定「存在窗口」

可信时间证据不能恢复已泄露密钥的可信性，它只能帮助判断某条记录是否在确定的最早可能失效边界之前已经存在。泄露起点不明时，后来取得锚点不能让身份结论变为通过；泄露后的轮换也不能替代独立恢复授权（K3 未实现，按人工流程停止与重新接入）。

6 验证与证据

这套设计靠可复跑的对抗性测试推进，而不是一次性写对。当前证据：

证据	**结果**
产品测试（9 套）	109/109
协议冻结矩阵	17/17（含 v0.2 真实导出样例）
独立密码学交叉验证	11/11（自写规范化 + cryptography Ed25519，不导入产品代码）
schema 实例校验	12/12 正常；6/6 破坏被拒（Ajv）
向量重建确定性	101/101 字节一致
fuzz	300/300 畸形包不崩溃、不被判为完全有效
旧格式兼容	0.6.1 黄金语料在 0.9.x 仍可验
CI	本地 15/15；**远端 CI 未运行**

说明：以上为本地运行证据；没有第三方独立审计，也没有客户付费验证。

6.1 版本基线

层	值
产品	agentbridge 0.9.3（tag v0.9.3）
协议	evidence-pack v0.2（技术冻结；批准签署待补）
代码提交	641a53a2f3394a953033bb13eb5588bd52262a15
发行物	agentbridge-0.9.3-release.zip（校验和见冻结快照）

6.2 测试能支持什么、不能支持什么

固定向量、真实桥导出与独立密码学校验，支持已覆盖场景的正确性判断；不能据此推导所有攻击或故障都已覆盖。结构变异测试不等于语义级安全验证；崩溃、磁盘满、跨机复制等故障尚未充分覆盖；真实接收方能否独立使用、是否愿意付费，仍需演练验证。

6.3 一个真实端到端样例

真实桥执行：提交 v1 → 拒收 → 密钥轮换 → 修订 v2 → 验收 v2 → 导出证据包 → 离线核验。验证器六轴通过（内容轴为 not_executed），旧版本拒收被标记 superseded，轮换后的签署由新钥验证。

6.4 已知限制

- 内容复核未实现（hashes_only）；要复核文件内容需后续模式。
- K3 紧急恢复未实现：密钥丢失/泄露按人工流程停止与重新接入。
- 并发导出用共享锁阻塞写入，但崩溃、磁盘满、跨机复制未覆盖。
- 多任务批量导出、项目隔离、保留与加密属企业功能，尚未完成。

7　商业价值：卖的是争议发生时的确定性

不要把它理解成「又一个日志系统」。客户真正买的是下面三件事：

7.1　对账更快

交付出了问题时，双方不再翻聊天记录：拿出证据包，十分钟内对齐「哪一版、谁验收、为什么拒收」。省下的是会议、邮件、律师函，以及最贵的——互相猜疑的时间。

7.2　责任更清

验收绑定版本，拒收带理由，修订有链路。谁在什么时间确认了什么，写进可核验的记录，而不是靠事后回忆。对跨组织协作，这直接影响返工成本与尾款周期。

7.3　对端能独立核验

差异不在「我们也有哈希链」，而在**接收方不需要购买、不需要联网、不需要信任我们**，用一个开源验证器和一份证据包就能复核。这把它从「自证」变成「他证」。

7.4　为什么现在

AI 交付的规模在涨，交付物从「文档」变成「代码、数据、模型输出」，跨组织协作变多，而现有合同、邮件、平台记录都没有为「AI 生成 + 多版本 + 快速迭代」设计证据格式。这是新预算，不是旧日志预算的替换。

商业假设需验证：目前没有客户访谈、付费试点或成交数据；上述价值判断是待验证假设，不是已验证结论。

8　客户与场景

8.1　AI 服务商 → 客户（优先试点）

按项目交付代码/报告/数据，交付频繁、版本多、验收标准明确；争议时最需要「对账」。

8.2 平台 → 第三方 Agent（组件/白标）

平台需要给第三方 Agent 做准入、交付核验与责任边界；agentbridge 作为可集成组件，而不是平台自己造一套。

8.3 受监管供应链（审计驱动）

金融、医疗、政务供应商需要向甲方或审计方证明「交付确实发生、内容未变、谁签的」。

8.4 企业内部多 Agent（次要）

已有日志系统的团队通常先用自己的日志；只有跨部门/跨权限、有经济后果时才需要独立存证。

客户筛选标准：协作跨组织或跨管理权限，且交付有明确经济后果；近 12 个月发生过交付争议或审计取证。

9 行业定位：AI 安全中的取证层

agentbridge 属于 AI 安全，但属于其中「身份、交付完整性、防篡改审计」这一格，不是模型防火墙、内容安全或对齐。

9.1 与 OWASP AISVS C9.4 的对应

OWASP AISVS 1.0 的 C9.4 标题为「Agent and Orchestrator Identity, Signing, and Tamper-Evident Audit」（Agent 与编排器身份、签名与防篡改审计），围绕独立身份、执行链绑定、凭据轮换与持久化状态完整性提出控制要求。以下只引用控制方向，不复制原文；条目编号、级别与措辞以官方原文为准。

C9.4 控制方向	agentbridge 能支撑的	仍需部署/客户完成
独立密码学身份，并以独立主体向下游认证	actor 注册、Ed25519 签名、外部信任配置、身份时间线	每个 Agent 实例是否独立持钥、密钥是否隔离、下游是否按该身份认证
执行步骤与行动密码学绑定	交付/验收/修订与签名、版本摘要、账本关联	是否覆盖全部工具调用、任务委派与其他执行步骤；未接入事件不算已有证据
凭据按计划轮换并处理逾期	轮换/撤销命令、历史密钥验证、按记录选钥	轮换周期、调度、逾期处理与运行记录仍需组织落实
跨调用持久状态完整性保护	已纳入范围的交付历史与密钥历史有哈希链、原始记录与外部检查点	Agent 记忆、计划、运行检查点等其他状态需另行接入，不自动受保护

结论边界：可以支撑 C9.4 的部分控制实施与证据收集，但不提供 OWASP 认证或全面符合性结论；部署评估应逐项记录覆盖范围、配置、测试证据与剩余缺口。标准提供控制语言，但不直接证明采购需求——客户是否愿意为独立证据层付费，仍需真实试点验证。

标准依据：OWASP AISVS 1.0，C9.4。官方链接：https://github.com/OWASP/AISVS/blob/main/1.0/en/0x10-C09-Orchestration-and-Agentic-Action.md

9.2 它不属于什么

它不防 prompt injection、越狱、数据投毒。前者走攻防预算，后者走合规与审计预算；这不是措辞差异，而是买方与采购路径的差异。

10　商业模式与路线

层	形态	收费
核心库与验证器	MIT 开源、零运行时依赖	免费（对端采用的前提）
集成与试点	接入现有交付流程、证据包格式落地	实施费
企业支持	部署、升级、SLA、审计配合	年度支持
托管锚点/证据保留	机器之外的签名回执与保留服务	订阅（待验证）

不做什么：不做裁决、不做资金托管、不做通用区块链存证；也不把「用哈希链」当卖点——客户买的是省下来的对账工作与可被第三方接受的证据。

10.1　价值怎么衡量（待验证）

年度可量化收益 ≈ 节省的调查工时 × 单位人工成本 + 节省的证据整理工时 × 成本 + 减少的重复维护成本 − 集成与运营成本。不要把「留存证据」直接换算成「避免全部事故损失」；事故损失只有在有证据时才可计入。

付费意愿分三档记录：口头认可、接受具体报价、实际付款。技术演练通过不以付费为条件，但只有更强的商业证据才支持扩大投入。

10.2 路线

阶段	内容	状态
已完成	账本/信封/身份/传输/锚点；证据包 v0.2；验收与修订；密钥时间线；CI/fuzz	0.9.3，v0.2 技术冻结
下一步	真实接收方演练；试点准入；付费验证	进行中/待启动
之后	K3 紧急恢复、内容复核模式、企业保留/隔离	未开始
更远	透明日志式锚点、跨组织信任联盟	研究

当前判断：适合「平台集成组件 + 企业服务」，尚不足以证明能成为独立规模化 SaaS；先做小规模付费验证，再决定通用平台投入。

11 术语表

术语	含义
条目 entry	账本一行：类型、actor、seq、prev、digest、签名
信封 envelope	一次请求/交付的正文与附件清单，含签名
验收 acceptance	接收方对指定版本与哈希集合的接受/拒收记录
修订 revision	同一逻辑交付的新版本，previous_version 指向上一个版本
证据包	可离线核验的交付凭证；manifest + originals
密钥时间线	register/rotate/revoke 事件，按账本序号选择当时有效钥
外部锚点	机器之外的 (seq, digest) 或服务签名回执
hashes_only	证据包只带摘要、不带附件内容；内容轴标记

	not_executed

附录 A　一句话总结

agentbridge 不证明 AI 做得好，只证明「这一版确实交给了你、你确实收下了、这条记录没被改过」——并把「哪些没被证明」写在报告里。争议发生时，这就够了。

附录 B　资料与依据

1. 本白皮书 v0.9.3（2026-10-21）：产品能力、验证数字与限制。

2. 证据包 v0.2 协议与 schema（技术冻结，提交 641a53a）：字段、验证语义与拒绝规则。

3. 冻结记录与 frozen/evidence-pack-v0.2/MANIFEST.sha256：完整摘要、发行物与批准状态。

4. 商业化与产品路线评审纪要 v1.1（2026-10-21）：目标客户、商业假设与边界。

5. 进展与困难报告（2026-10-21）：工程状态、已知缺口与试点条件。

6. OWASP AISVS 1.0 C9.4 官方原文：需求框架与条目映射依据（链接见 9.1）。

AI 辅助评审不构成独立审计签字；本白皮书不增加认证、合规通过或生产安全保证。